

Mukesh Patel School of Technology Management & Engineering
School of Technology Management and Engineering

Course Policy Document

Course Name: Application Security Testing (AST)

Program and Semester: B. Tech. Computer Science and Engineering (Cybersecurity) / Sem VI	Pre-requisite Course: NA					
Academic Year: 2024-25	Credit Details:	L	T	P	C	H
		2	0	2	3	4
Name of Course Faculty: Pratidnya S. Hegde Patil Program: BTech CYS Contact Details: 9833191987; pratidnya.hegdepatil@nmims.edu Office Hours:	Faculty associated with the course: - 1. Pratidnya S. Hegde Patil					
Pre-Course Activity: Using GenAI, explore the following 1. Study the components of OWASP for Web and Mobile 2. Features of BurpSuite Create a login in Burp Suite (for Lab Experiments/In class Tutorials) and Overleaf (for writing Research Paper) Explore BurpSuite official website to find out how to install and the basic requirements for installing. Explore the tutorials and the video provided on the website.						
Course link:						

1. Introduction to the Course

1.1 Importance of the Course

1.1.1 Domain Relevance:

This course aims to equip learners with a comprehensive understanding of application security principles, methodologies, and practices across diverse software environments. By exploring modern application architectures, secure software lifecycle models, and software security frameworks, the course provides the knowledge and skills required to identify, test, and mitigate vulnerabilities in web and mobile applications.

1.1.2 Industry Relevance:

The course covers industry-recognized frameworks and methodologies, such as OWASP, NIST, CWE ensuring learners are prepared to work with globally accepted security practices.

Understanding the OWASP Top 10 and CWE helps professionals address the most critical vulnerabilities encountered in real-world scenarios.

1.2 Objectives of the Course:

- 1.2.1** The objective of this course is to provide learners with a comprehensive understanding of application security principles, practices, and methodologies to safeguard modern software systems against vulnerabilities and cyber threats.
- 1.2.2** Writing a Research Paper on new emerging topics of Cybersecurity will expose them to relevant literature and help them go through the research process.

2. Course Outcomes (CO), Mapping with Program Outcomes (PO), and Program Specific Outcomes (PSO)

2.1 Course Outcomes

- 2.1.1 CO1:** Describe various testing methodologies.
- 2.1.2 CO2:** Perform security testing of web and mobile applications.
- 2.1.3 CO3:** Suggest countermeasure to mitigate vulnerabilities.

2.2 Program Outcomes(PO) the course contributed to:

- 2.2.1 PO-1:** An ability to apply knowledge of mathematics, science, and engineering for problem solving.
- 2.2.2 PO-2:** An ability to research, design and conduct experiments, as well as to analyze and interpret data.
- 2.2.3 PO-3:** An ability to design, implement, and evaluate a computer-based system, process, component, or program to meet desired needs.
- 2.2.4 PO-4:** An ability to function effectively on teams to accomplish a common goal.
- 2.2.5 PO-5:** An ability to identify, formulate and provide effective IT solution for engineering problems.
- 2.2.6 PO-6:** An understanding of professional, legal, security and social issues and responsibilities.
- 2.2.7 PO-7:** An ability to communicate effectively with a range of audiences.

2.2.8 PO-8: The broad education necessary to understand the impact of engineering solutions in a global, economic, environmental, and societal context.

2.2.9 PO-9: Recognition of the need for and an ability to engage in continuing professional development and self-learning.

2.2.10 PO-10: An ability to apply ethical principles in development of IT solutions.

2.2.11 PO-11: An ability to use the techniques, skills, and modern engineering tools necessary for developing effective IT solutions.

2.2.12 PO-12: An ability to identify and analyze user needs and take them into account in the selection, creation/integration, evaluation and administration of IT-based solutions.

2.3 Program Specific Outcomes (PSO):

2.3.1 PSO-1: Demonstrate an ability to visualize, architect and create appropriate solutions for IT related projects.

2.3.2 PSO-2: Demonstrate an ability to professionally manage, monitor and safeguard IT resources.

CO-PO Mapping

	PO1	PO2	PO3	PO4	PO5	PO6	PO7	PO8	PO9	PO10	PO11	PO12	PSO1	PSO2
CO1						2				2				
CO2						2				2	2			
CO3						2				2	2			

Mapping Levels: 1- High, 2-Medium, 3-Low

2.4 Student Outcomes (SO) (For ABET accredited Programs):

2.4.1 SO-1: Analyze a complex computing problem and to apply principles of computing and other relevant disciplines to identify solutions.

2.4.2 SO-2: Design, implement, and evaluate a computing-based solution to meet a given set of computing requirements in the context of the program's discipline.

2.4.3 SO-3: Communicate effectively in a variety of professional contexts.

2.4.4 SO-4: Recognize professional responsibilities and make informed judgments in computing practice based on legal and ethical principles.

2.4.5 SO-5: Function effectively as a member or leader of a team engaged in activities appropriate to the program's discipline.

2.4.6 SO-6: Identify and analyze user needs and to take them into account in the selection, creation, integration, evaluation, and administration of computing-based systems.

3. Teaching-learning methodology

3.1 Instruction Plan

[illegible]

10	Software vulnerabilities and its types and countermeasures	PPT, Whiteboard	UNDERSTAND	Reading material and web links provided by faculty, NIST, OWASP, TB 14	CO1, CO2	Class Test1 and 2
11	Software vulnerabilities and its types and countermeasures					
12	Software vulnerabilities detection mechanism, Testing					
13	Frameworks (NIST, OWASP)					
14	Frameworks (NIST, OWASP)					
Unit 4: Web App Security and Testing						
15	Pen testing Methodology	PPT, Whiteboard, Demonstration	APPLY	Reading material and web links provided by faculty, NIST, OWASP, TB 3-8	CO2,CO3	Lab Submissions based on Web and Mobile, Practical Assignment, Research Paper Writing
16	Testing of authentication					
17	Session management					
18	Secure channels, secure access control, data and information disclosure					
19	Injection attack					
20	CSRF , Server side template injection					
21	Clickjacking, XSS					
22	HTTP request smuggling					

23	Web tutorials of Burp Suite					
24	OAuth Authentication, API Testing and counter measures					
Unit 5: Mobile App Security and Testing						
25	OWASP Mobile	PPT, Whiteboard, Demonstration	UNDERSTAND	Reading material and web links provided by faculty, OWASP	CO2, CO3	Lab Submissions based on Web and Mobile, Practical Assignment, Research Paper Writing
26	Types of mobile apps		APPLY			
27	Challenges in mobile testing					
28	Counter measures					
29	Mobile Tutorials of Burp Suite					
30	Mobile Tutorials of Burp Suite					

4. Assessment and Evaluation Scheme

	Internal Continuous Assessment (ICA) (50 Marks)				
	Class Tests (20 Marks)		Term-work (30 Marks)		
Assessment Component	Class Test-1	Class Test-2	Lab Submissions	Practical Assignment (In-class discussion and Home)	Research Paper Writing (Survey/Technical)
Marks	10	10	05	05	20

4.1 Internal Continuous Assessment (ICA) – 50 marks

1. Class Test1 Lab Exam1 (10 marks) (Tentative Syllabus)

2. Class Test2 Lab Exam2 (10 marks) (Tentative Syllabus)

3. Lab performance evaluation (05 marks)

Ten Lab experiments (15 marks each scaled to 05 marks)

- Continuous assessment for laboratory experiments will be conducted. There are 10 practicals, each carrying weightage of 15 marks. At the end of the course, average of total marks will be taken to obtain marks out of 15.

- ii. Out of the 15 marks for a practical, student will be evaluated out of 10 Marks (5 deducted) if the student submits late or is absent for the practical.
- iii. Discussion of your work with your peers is allowed. However, each student is expected to submit his/her original work. Submissions which are very similar will be marked zero. Assessment of each practical experiment is based on rubrics attached as Point 10.

4. Research Paper Writing (20 marks)

- i. Faculty will make group of 2-3 students
- ii. Identify a topic relevant to the course
- iii. Get the topic approval
- iv. Write the Paper using IEEE template (Two column) in Overleaf
- v. Research Paper to be written in Latex (use Overleaf) to be submitted and the Latex Manuscript to be presented
- vi. Assessment will be based the Breakup and Rubrics given in Point 10

5. Class Participation – Practical Assignment (10 scaled to 5 marks)

Practical Assignment on Cyber Problem Statements other than taken in practicals. (CO3)

- i. This assignment has to be done individually.
- ii. Identify a topic relevant to the course (New Tool / Topic not covered in course).
- iii. Design an Experiment for the chosen Tool/Topic containing steps to implement the designed experiment.

#	Practical Assignment Breakup	Marks	CO#	SO #
1	EXPERIMENT: Design one Experiment: • Part A-State the student outcome, Scenario and what is expected from the Experiment, • Part B-Design Ten MCQs based on Experiment and Technology chosen, • Part C-Answer stepwise to Part A & Part B. (attach screen shots/code wherever required).	5	CO-3	SO -6

50% marks would be deducted for late submissions. (It is important that all assignments i.e. Practical Assignment, Research Paper Writing and lab submissions are done before the deadline given).

4.2 Term End Examination (TEE) – 100 marks scaled to 50

4.3 Course Passing Criteria

4.3.1 ICA above zero for passing

4.3.2 TEE 40% passing and aggregate (TEE+ICA) 50% passing

4.4 Assessments and Mapping to Course Outcomes

	Internal Continuous Assessment (ICA)				
Course Outcomes	CT-1	CT-2	Lab Submissions	Research Paper Writing	Practical Assignment

CO-1	Y	Y			
CO-2	Y	Y	Y	Y	
CO-3		Y	Y	Y	Y

5. Laboratory details

The following 10 programming exercises will form the submission for laboratory coursework. Each programming exercise will contain one workable app to be created.

Exp. No.	Week No.#	Programming Topic	Mapped CO
1.	Week 1	In-band SQL Injection	CO-2, CO-3
2.	Week 2	Blind SQL Injection	CO-2, CO-3
3.	Week 3	Server-side request forgery (SSRF)	CO-2, CO-3
4.	Week 4	Cross-site request forgery (CSRF)	CO-2, CO-3
5.	Week 5	HTTP request smuggling	CO-2, CO-3
	Week 6	Class Test1	
6.	Week 7	Server-side template injection	CO-2, CO-3
7.	Week 8	Clickjacking	CO-2, CO-3
8.	Week 9	Authentication	CO-2, CO-3
9.	Week 10	Cross-site scripting (XSS)	CO-2, CO-3
10.	Week11	OAuth Authentication	CO-2, CO-3
	Week 12	Class Test2	
11.	Week 13/14	Extra/Revision	
12.	Week 15	Research Paper submission	

6. Tutorial Plan

This course does not have any tutorial.

7. Course Material

References and Lab Manuals would be uploaded on Teams/portal by faculty every week.

8. GenAI Usage

8.1 Pre-class Activity:

- Burp Suite Installation and Working know-how.
- Latex know-how to help in framing the Research paper.

8.2 Assignments

GenAI is not to be used for doing Assignments like Lab Experiments/Research Paper Writing/Practical Assignment given by faculty.

9. Academic Integrity Statement

Original work expected from students for all of the **assigned assessment work**. Copying in any form not acceptable and will invite strict disciplinary action. Evaluation of corresponding component will be affected proportionately in such cases. Plagiarism detection software will be used to check plagiarism wherever applicable. Academic integrity is expected from students in all components of course assessment.

10. Rubrics (Lab Experiments, Lab Report and Project Work)

Practical Write-up Submission Rubrics (15 Marks each Experiment, Total 150 scaled to 5 Marks):

1. Preparedness and Efforts	3: Well prepared and puts efforts	2: Not prepared but puts efforts or prepared but doesn't put efforts	1: Neither prepared nor puts efforts
2. Knowledge of concepts and tools	3: Good knowledge	2: Partial knowledge	1: Minimal knowledge
3. Debugging and results	3: Gets accurate results and can debug errors	2: Does not get expected results and needs some help from faculty to debug	1: Doesn't get results and cannot debug
4. Punctuality	3: Gets all the experiments checked in-time and is always in-time to the lab sessions	2: Some time delays the experiment checking or is late to the lab sessions for few times	1: Most of the time delays experiment checking and / or comes late for lab sessions
5. Documentation	3: Outstanding documentation	2: Above average documentation	1: Poor documentation

Research Paper Writing (20 Marks):

1. Originality of Problem Statement.	4: Excellent	3: Good	2-1: Satisfactory
2. Paper Abstract. (Considering User Needs and express it to public.)	5: Excellent	4-3: Good	2-1: Satisfactory
3. Design and Implementation. (Addressing and Mitigating the Risk.)	5: Excellent	4-3: Good	2-1: Satisfactory
4. Individual contribution.	5: Excellent (All instructions given followed. Contribution with relevant evidence and team spirit demonstrated)	4-3: Good (Contribution defined, Evidence not relevant to the requirements given, team spirit demonstrated)	2-1: Satisfactory (Contribution defined, Evidence not relevant, team spirit marginally demonstrated)
5. Submission in reputed conferences and Journal.	1: Yes	0: No	

Practical Assignment Rubric (5 Marks):

Design of Practical Writeup (Reproducible, installation if applicable explained, Q&A, Based on new topic not covered in course)	5: Excellent	4-3: Good	2-1: Satisfactory
--	--------------	-----------	-------------------

*** - Only Teaching Method in the Instruction Plan for the course may vary for different faculty teaching the course, rest of the Course Policy Document will not change.**